

TÓM TẮT NỘI DUNG ĐỒ ÁN

Trong bối cảnh chuyển đổi số, các ngân hàng triển khai ngày càng nhiều hệ thống ứng dụng nội bộ, kéo theo bài toán quản lý quyền truy cập cho đội ngũ lập trình viên trở nên phức tạp hơn đáng kể. Các giải pháp IAM phổ biến như Keycloak hay Microsoft Azure AD cung cấp đầy đủ cơ chế xác thực theo chuẩn nhưng chưa đáp ứng tốt đặc thù của ngân hàng: vòng đời quyền chưa gắn chặt với vòng đời nhân sự, quy trình phê duyệt nội bộ phải bổ sung bên ngoài hệ thống, và việc thu hồi quyền tức thì khi có sự cố vẫn phụ thuộc vào thời gian hết hạn tự nhiên của token. Những hạn chế này làm gia tăng rủi ro bảo mật và chi phí vận hành thủ công.

Đề tài lựa chọn hướng tự xây dựng một nền tảng IAM nội bộ, lấy mô hình phân quyền dựa trên vai trò (RBAC) làm nền tảng, kết hợp với các chuẩn xác thực OAuth2 và OpenID Connect, triển khai theo kiến trúc microservices kết hợp hướng sự kiện (event-driven). Hướng tiếp cận này cho phép tùy biến sâu theo đặc thù nghiệp vụ trong khi vẫn tuân thủ các chuẩn giao thức mở, đồng thời tránh rủi ro phụ thuộc nhà cung cấp vốn tiềm ẩn trong các giải pháp thương mại.

Trên cơ sở các công nghệ và phương pháp đã lựa chọn, đề tài thiết kế và xây dựng một hệ thống IAM hoàn chỉnh bao gồm các thành phần xử lý xác thực, quản lý vòng đời người dùng, cấu hình phân quyền và kiểm soát truy cập tại gateway. Tính đúng đắn của giải pháp được kiểm chứng thông qua một ứng dụng nghiệp vụ nội bộ mô phỏng quy trình quản lý thay đổi phần mềm, trong đó toàn bộ kiểm soát quyền truy cập được thực thi tập trung bởi nền tảng IAM.

Đóng góp chính của đề tài tập trung vào ba điểm kỹ thuật nổi bật. Thứ nhất, mô hình RBAC được mở rộng với chiều vị trí công tác (cấp vai trò–vị trí), cho phép tự động cấp quyền mặc định khi nhân sự được tiếp nhận hoặc luân chuyển mà không cần thao tác thủ công từ quản trị viên. Thứ hai, vòng đời quyền được tự động hóa hoàn toàn thông qua sự kiện Kafka, kết hợp với quy trình phê duyệt của hội đồng CAB (Change Advisory Board) có nhật ký kiểm toán đầy đủ cho các quyền bổ sung. Thứ ba, cơ chế thu hồi quyền tức thì qua Kafka đảm bảo phiên làm việc bị vô hiệu hóa trong vài giây sau khi quyền bị thu hồi, thay vì chờ token hết hạn như trong các hệ thống stateless thông thường. Kết quả cuối cùng là một hệ thống IAM hoàn chỉnh, giải quyết trực tiếp những hạn chế của các nền tảng thương mại hiện có trong bối cảnh đặc thù phát triển phần mềm ngân hàng.

Hà Nội, tháng 6 năm 2026

Sinh viên thực hiện

